

Πανεπιστήμιο Δυτικής Αττικής
Σχολή Μηχανικών
Τμήμα Μηχανικών Πληροφορικής και Υπολογιστών

Ασφάλεια στην τεχνολογία της πληροφορίας

4η Εργασία

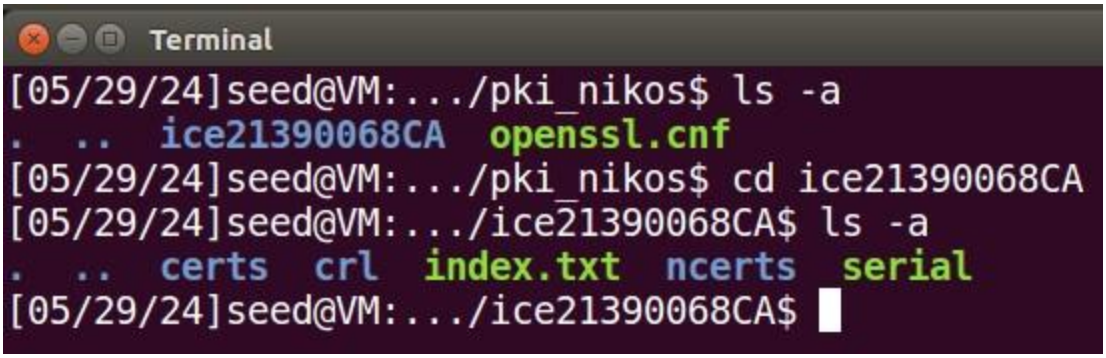
ΝΙΚΟΛΑΟΣ ΘΩΜΑΣ
ΑΜ: 21390068

ΑΘΗΝΑ

Περιεχόμενα

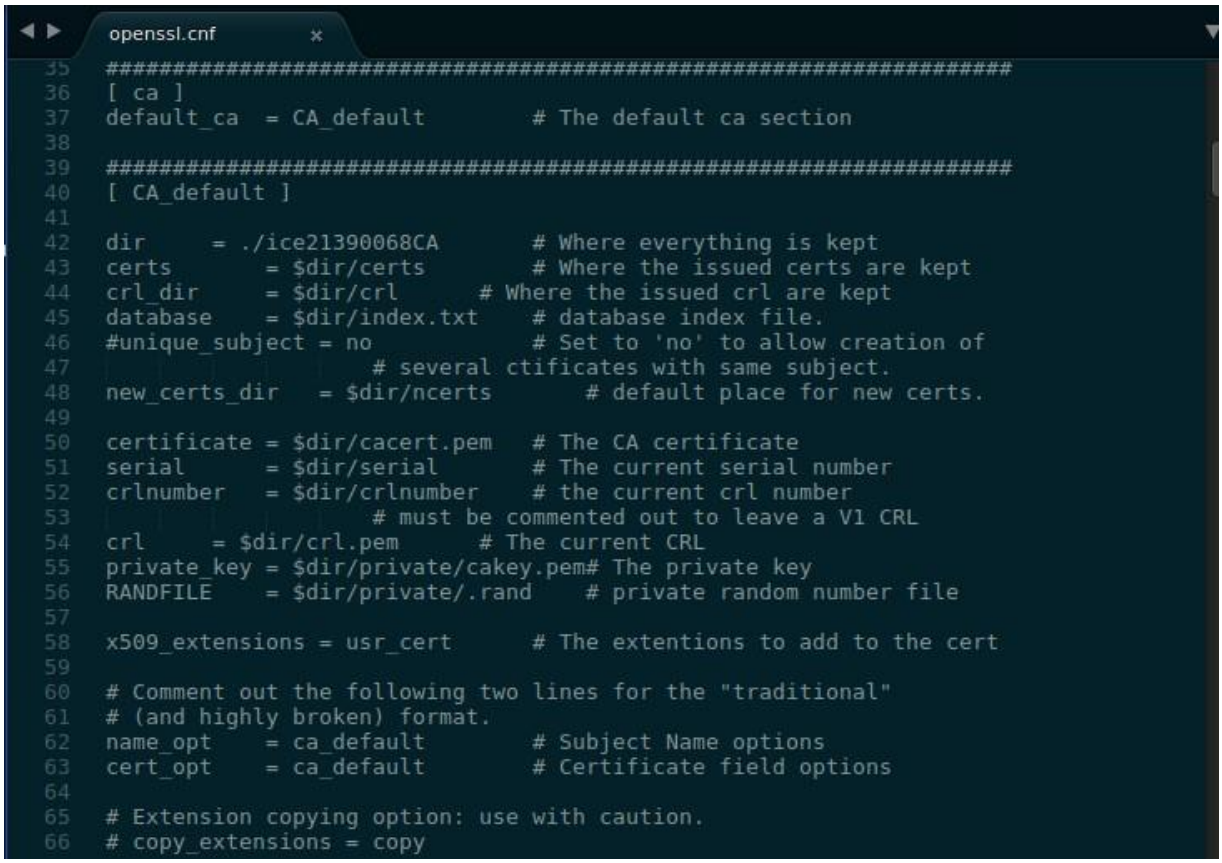
Δραστηριότητα 1: Δημιουργία Αρχής Πιστοποίησης 3
Δραστηριότητα 2: Έκδοση πιστοποιητικού για πελάτη 6
Δραστηριότητα 3: Χρήση του πιστοποιητικού σε δοκιμαστικό HTTPS Server 10
Δραστηριότητα 4: Χρήση του πιστοποιητικού σε Apache HTTPS Web server 14
Δραστηριότητα 5: Επίθεση τύπου Man-In-The-Middle 16
Δραστηριότητα 6: Επίθεση τύπου Man-In-The-Middle σε περίπτωση παραβιασμένης ΑΠ ... 18
Παραπομπές: 20

Δραστηριότητα 1: Δημιουργία Αρχής Πιστοποίησης



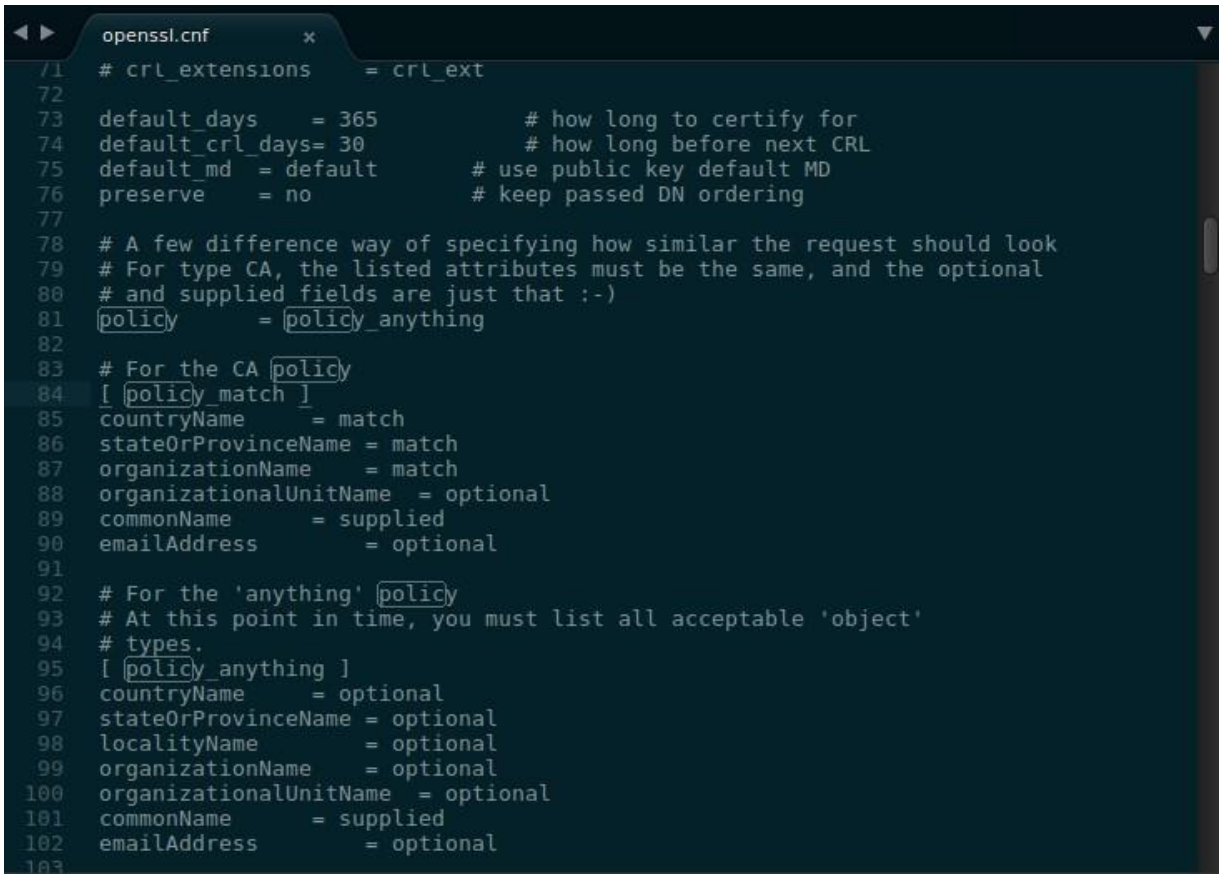
Εικόνα 1: Δομή καταλόγων της άσκησης.

Δημιουργούμε τα απαραίτητα αρχεία για την εκτέλεση της άσκησης.



Εικόνα 2: Ενημερωμένο openssl.cnf.

Στην συνέχεια αντιγράφουμε το openssl.cnf, το τροποποιούμε ώστε να συμβαδίζει με τα δικά μας αρχεία και αλλάζουμε το policy σε policy_anything.



Εικόνα 3: Ενημερωμένο openssl.cnf.

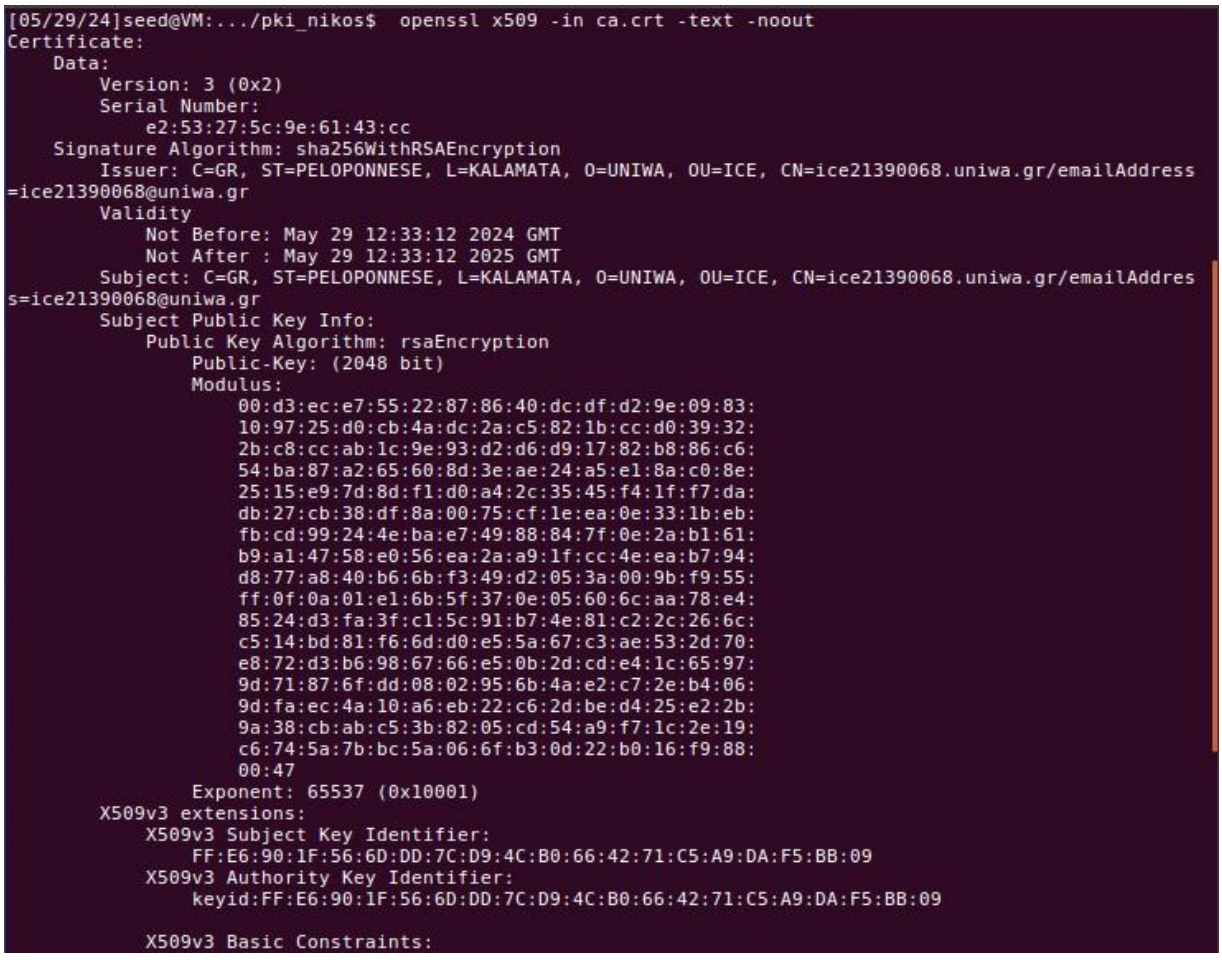
```
[05/29/24]seed@VM:.../ice21390068CA$ cd ..
[05/29/24]seed@VM:.../pki_nikos$ openssl req -new -x509 -keyout c
a.key -out ca.crt -days 365 -config openssl.cnf
Generating a 2048 bit RSA private key
..............................+++
.............+++
writing new private key to 'ca.key'
Enter PEM pass phrase:
Verifying - Enter PEM pass phrase:
-----
You are about to be asked to enter information that will be incor
porated
into your certificate request.
What you are about to enter is what is called a Distinguished Nam
e or a DN.
There are quite a few fields but you can leave some blank
For some fields there will be a default value,
If you enter '.', the field will be left blank.
-----
Country Name (2 letter code) [AU]:GR
State or Province Name (full name) [Some-State]:PELOPONNESE
Locality Name (eg, city) []:KALAMATA
```

Εικόνα 4: Δημιουργία αυτό-υπογεγραμμένου πιστοποιητικού.

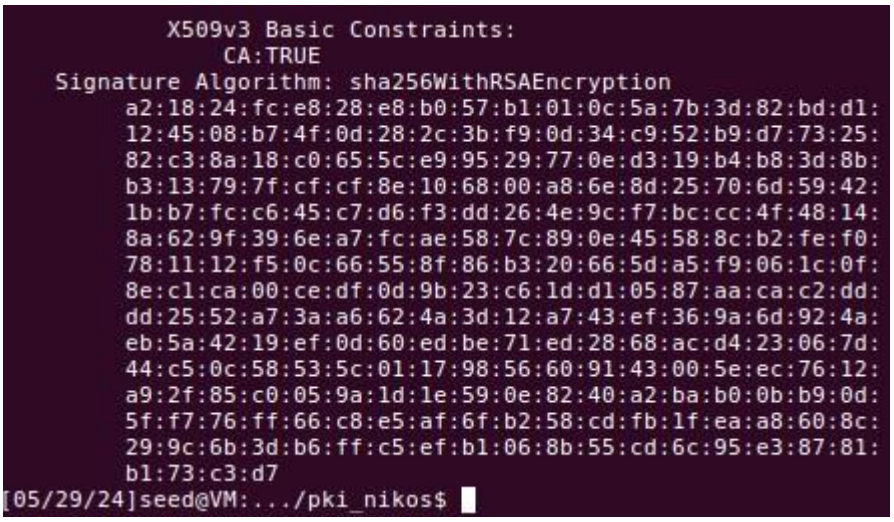


Εικόνα 5: Δημιουργία αυτό-υπογεγραμμένου πιστοποιητικού.

Δημιουργούμε ένα αυτό-υπογεγραμμένο πιστοποιητικό με την εντολή $ openssl req -new -x509 -keyout ca.key -out ca.crt -days 365 -config openssl.cnf. Συμπληρώνουμε τις απαραίτητες πληροφορίες και έτσι δημιουργούνται το ca.key που είναι το ιδιωτικό κλειδί και το ca.crt που περιέχει το πιστοποιητικό με το δημόσιο κλειδί.



Εικόνα 6: Περιεχόμενο πιστοποιητικού.



Εικόνα 7: Περιεχόμενο πιστοποιητικού.

Με την εντολή $ openssl x509 -in ca.crt -text -noout εμφανίζεται το περιεχόμενου του πιστοποιητικού.

Δραστηριότητα 2: Έκδοση πιστοποιητικού για πελάτη



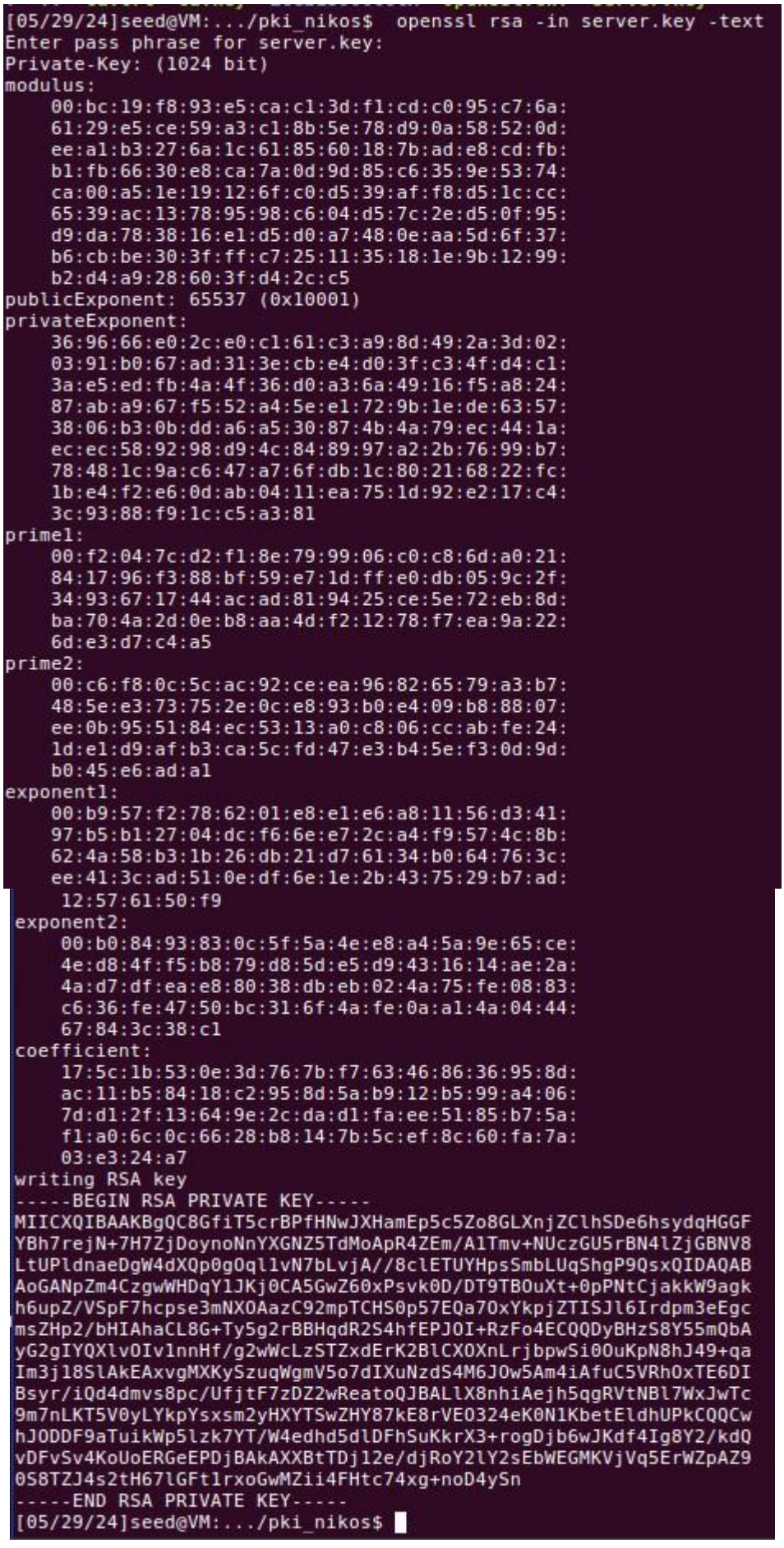
Εικόνα 8: Δημιουργία ζεύγους κλειδιών RSA για τον πελάτη.

Στη συνέχεια δημιουργούμε το ζεύγος κλειδιών RSA για τον πελάτη με την εντολή $ openssl genrsa -aes128 -out server.key 1024.



Εικόνα 9: Server.key.

Μετά την εντολή, δημιουργείται το server.key, ένα κρυπτογραφημένο αρχείο.



Εικόνα 10: Περιεχόμενα του αρχείου server.key.

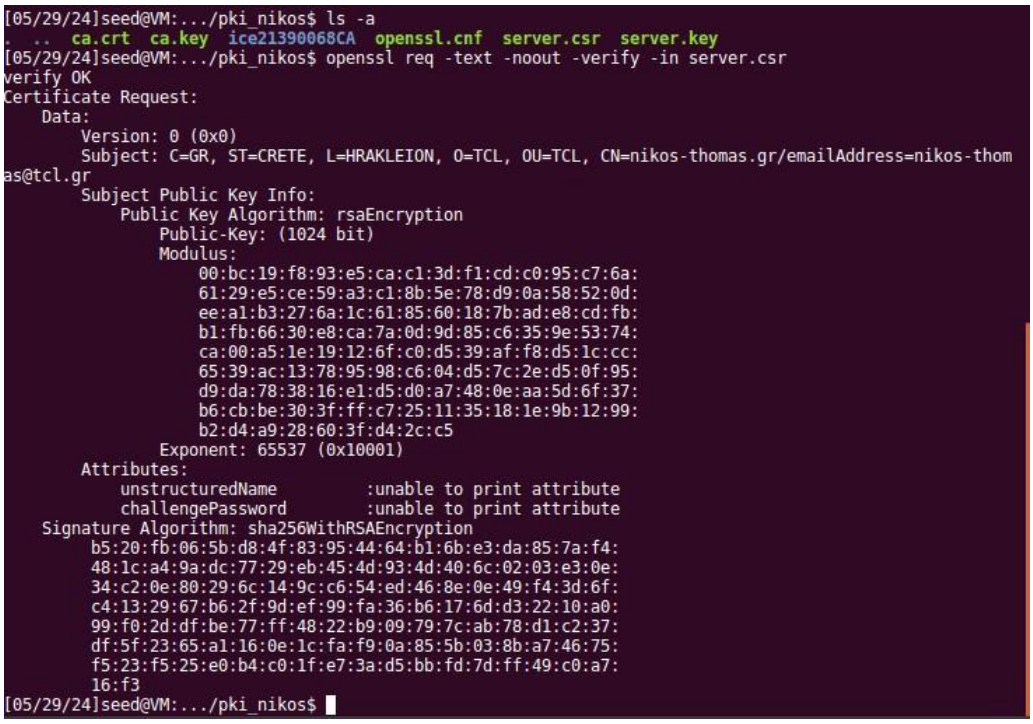
Με την εντολή $ openssl rsa -in server.key -text και τον κωδικό πρόσβασης μπορούμε να δούμε το περιεχόμενο του server.key.

```
[05/29/24]seed@VM:.../pki_nikos$ openssl req -new -key server.key -out s
erver.csr -config openssl.cnf
Enter pass phrase for server.key:
You are about to be asked to enter information that will be incorporated
into your certificate request.
What you are about to enter is what is called a Distinguished Name or a
DN.
There are quite a few fields but you can leave some blank
For some fields there will be a default value,
If you enter '.', the field will be left blank.
-----
Country Name (2 letter code) [AU]:GR
State or Province Name (full name) [Some-State]:CRETE
Locality Name (eg, city) []:HRAKLEION
Organization Name (eg, company) [Internet Widgits Pty Ltd]:TCL
Organizational Unit Name (eg, section) []:TCL
Common Name (e.g. server FQDN or YOUR name) []:nikos-thomas.gr
Email Address []:nikos-thomas@tcl.gr

Please enter the following 'extra' attributes
to be sent with your certificate request
A challenge password []:nikos
An optional company name []:tcl
[05/29/24]seed@VM:.../pki_nikos$
```

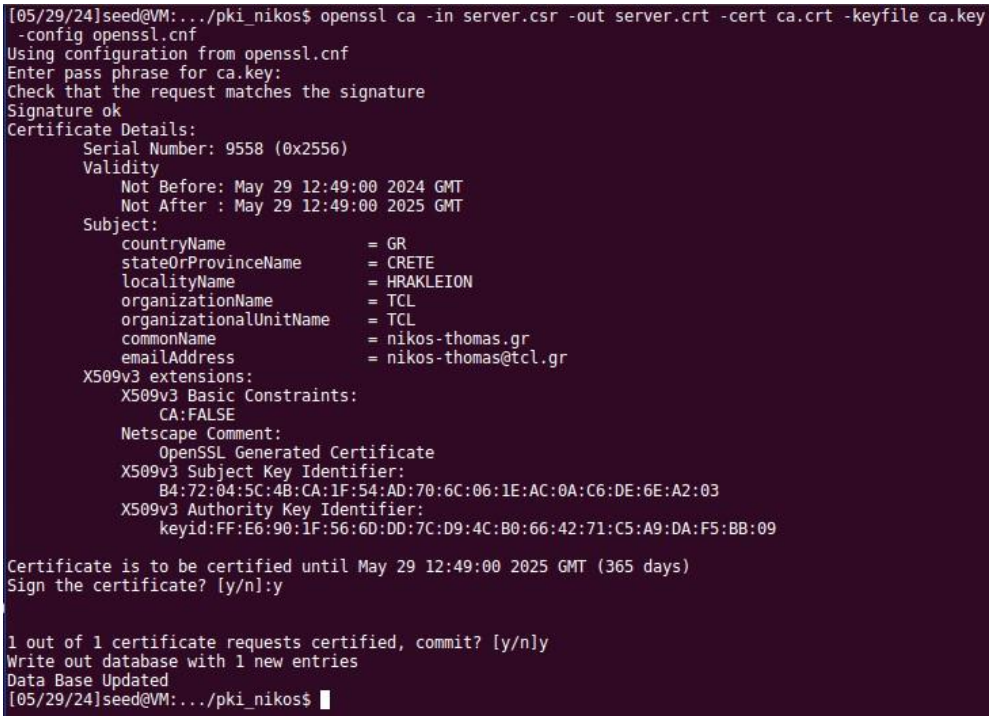
Εικόνα 11: Δημιουργία του CSR.

Δημιουργία του αιτήματος υπογραφής πιστοποιητικού (CSR) με την εντολή $ openssl req -new -key server.key -out server.csr -config openssl.cnf. Θα περιλαμβάνει το δημόσιο κλειδί του καθώς και πληροφορίες για την ταυτότητα του αιτούντος.



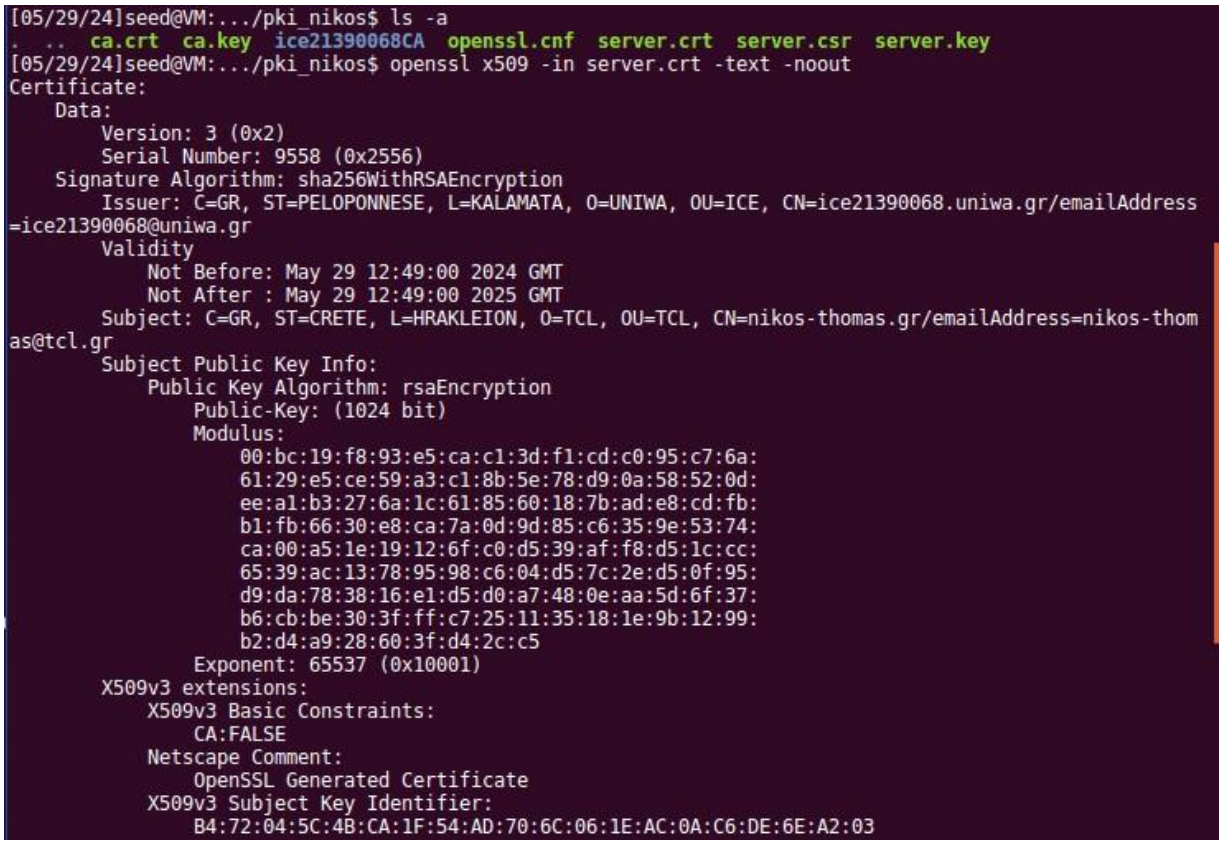
Εικόνα 12: Έλεγχος δημιουργίας CSR.

Μετά την εκτέλεση της εντολής, παρατηρούμε ότι δημιουργήθηκε το αρχείο server.csr.



Εικόνα 13: Υπογραφή του CSR από την ΑΠ.

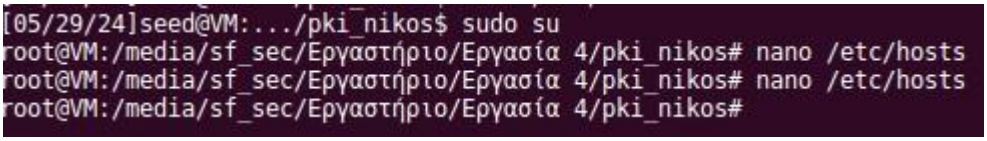
Στην συνέχεια, υπογράφουμε το αρχείο csr με την ΑΠ, με την εντολή $ openssl ca -in server.csr -out server.crt -cert ca.crt -keyfile ca.key -config openssl.cnf. Συμπληρώνουμε το passphrase και η διαδικασία ολοκληρώνεται.



Εικόνα 14: Περιεχόμενα server.crt.

Με την εντολή $ openssl x509 -in server.crt -text -noout, μπορούμε να δούμε το περιεχόμενο του server.crt.

Δραστηριότητα 3: Χρήση του πιστοποιητικού σε δοκιμαστικό HTTPS Server

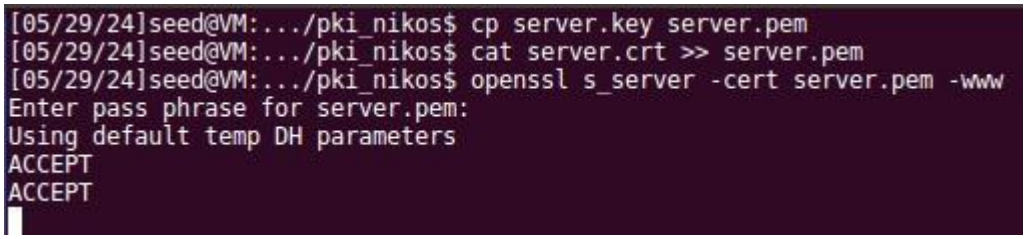


Εικόνα 15: Επεξεργασία του αρχείου hosts.

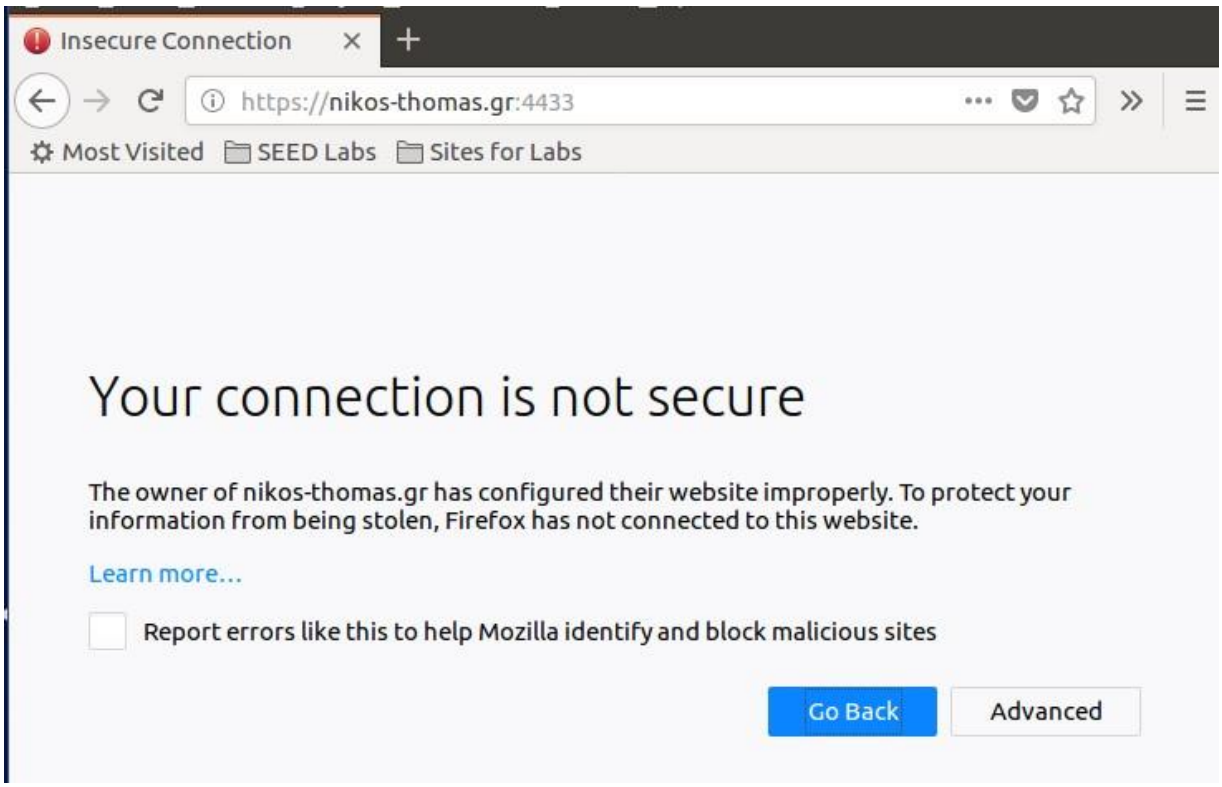
Για να προσομοιώσουμε τοπικά την διεύθυνσή μας, θα πρέπει να διαμορφώσουμε του DNS. Αυτό μπορεί να γίνει με την επεξεργασία του αρχείου /etc/hosts.



Εικόνα 16: Επεξεργασία του αρχείου hosts.



Εικόνα 17: Εκκίνηση του OpenSSL web server.

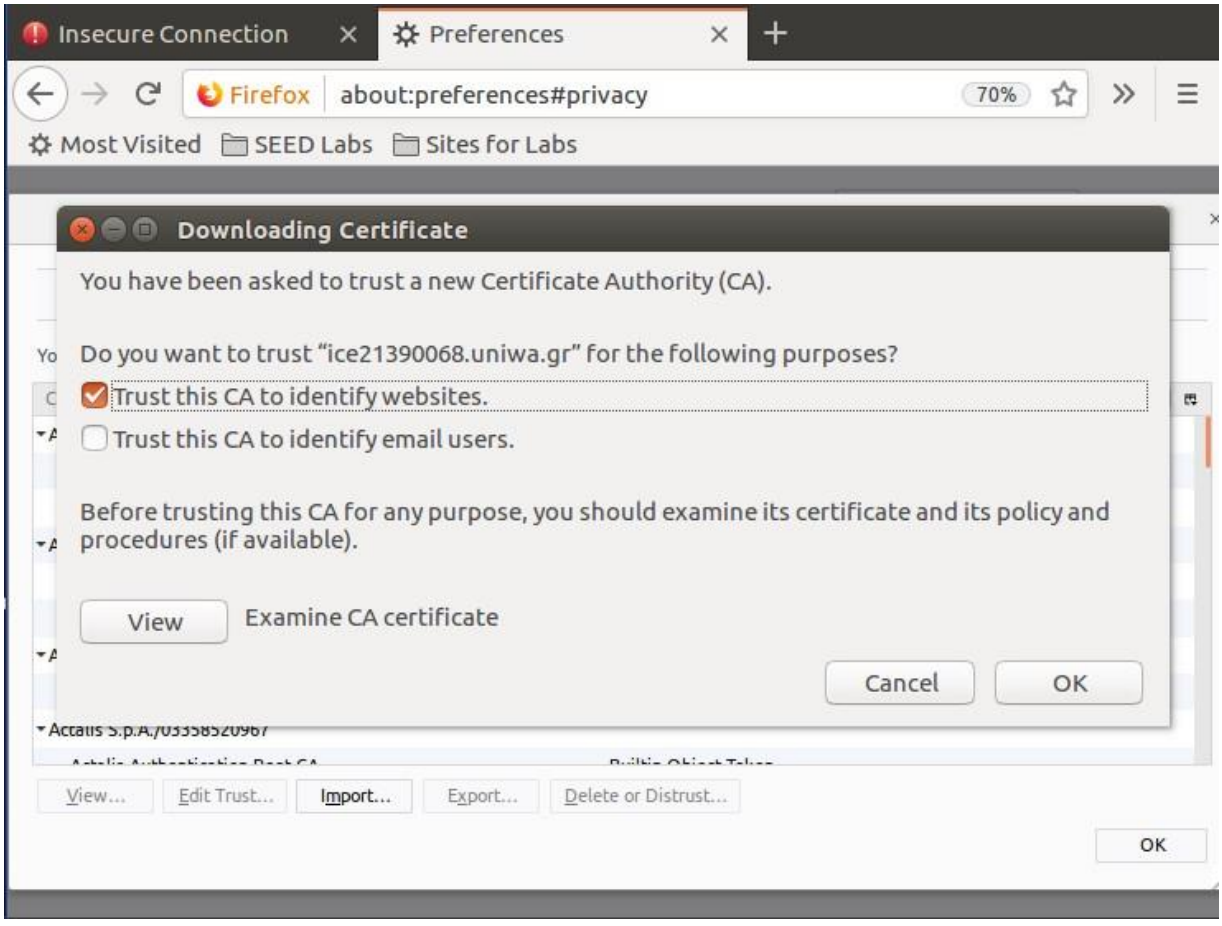


Εικόνα 18: Μη αποδεκτό πιστοποιητικό στον Firefox.

Παρατηρούμε ότι ο Firefox εμφανίζει μήνυμα πως η σύνδεση δεν είναι ασφαλής. Αυτό συμβαίνει γιατί δεν έχει το πιστοποιητικό μας.

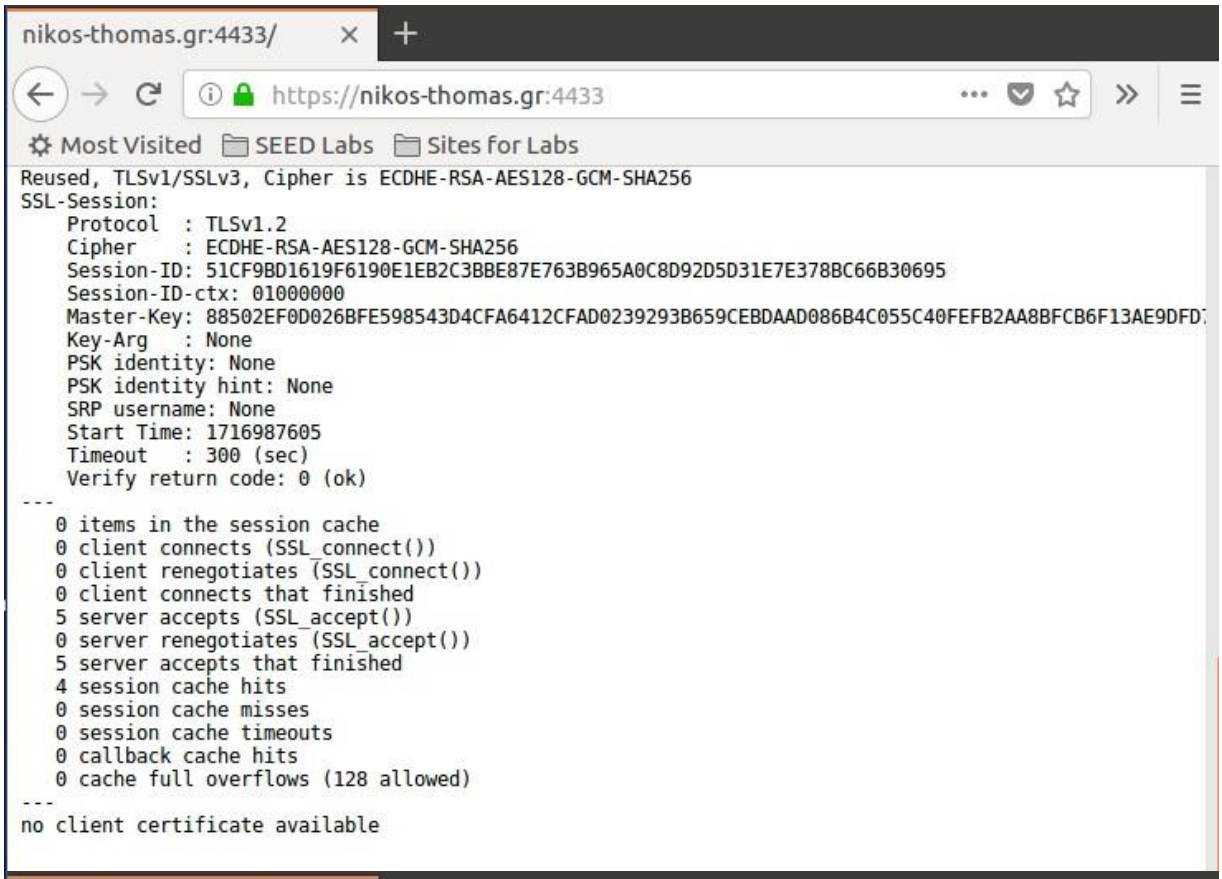


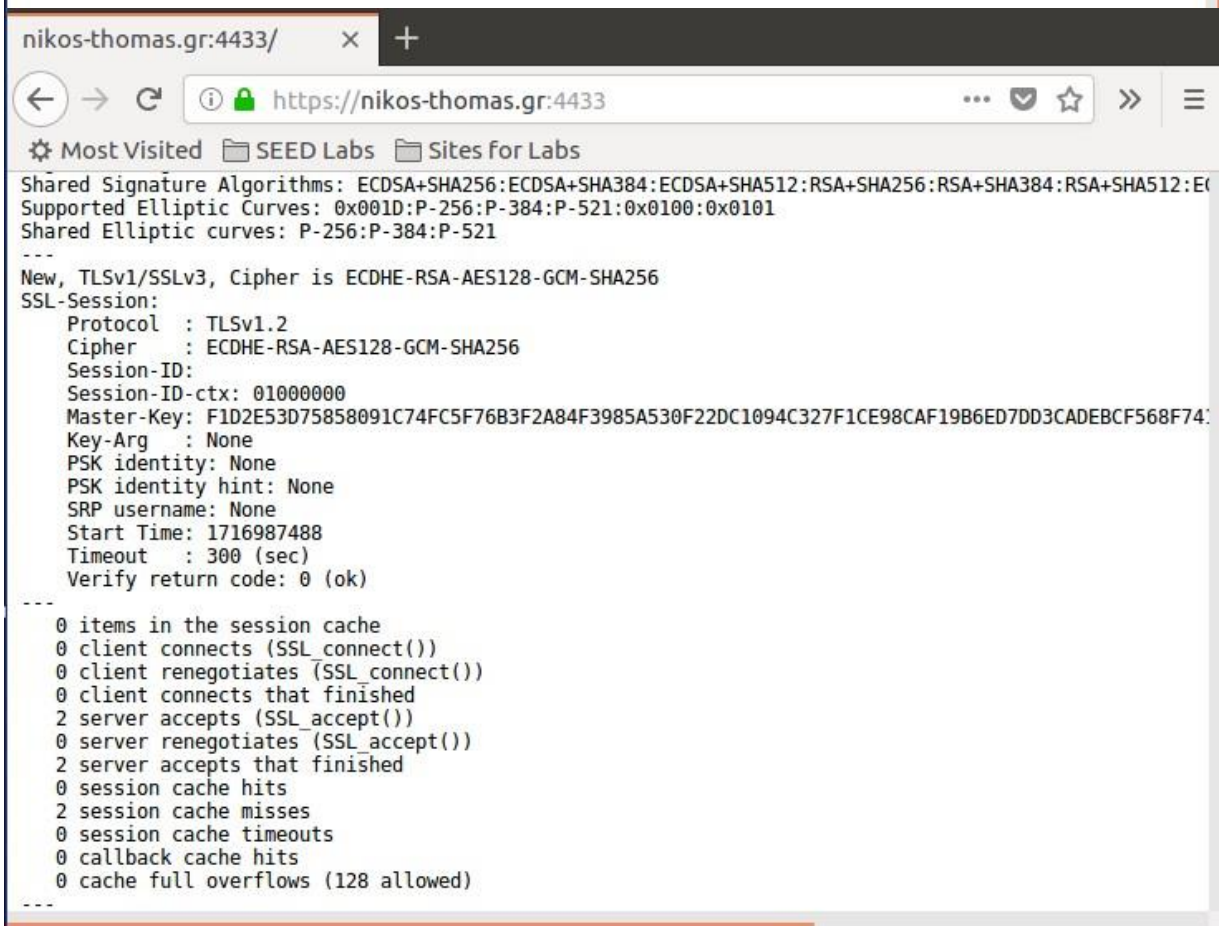
Εικόνα 19: Μη αποδεκτό πιστοποιητικό στον Firefox.



Εικόνα 20: Χειροκίνητη προσθήκη πιστοποιητικού στον Firefox.

Το πρόβλημα λύνεται με την εισαγωγή του πιστοποιητικού στον Firefox χειροκίνητα.


nikos-thomas.gr:4433/
https://nikos-thomas.gr:4433
Most Visited
SEED Labs
Sites for Labs
Reused, TLSv1/SSLv3, Cipher is ECDHE-RSA-AES128-GCM-SHA256
SSL-Session:
Protocol : TLSv1.2
Cipher : ECDHE-RSA-AES128-GCM-SHA256
Session-ID: 51CF9BD1619F6190E1EB2C3BBE87E763B965A0C8D92D5D31E7E378BC66B30695
Session-ID-ctx: 01000000
Master-Key: 88502EF0D026BFE598543D4CFA6412CFAD0239293B659CEBDAAD086B4C055C40FEFB2AA8BFCB6F13AE9DFD
Key-Arg : None
PSK identity: None
PSK identity hint: None
SRP username: None
Start Time: 1716987605
Timeout : 300 (sec)
Verify return code: 0 (ok)
---
0 items in the session cache
0 client connects (SSL_connect())
0 client renegotiates (SSL_connect())
0 client connects that finished
5 server accepts (SSL_accept())
0 server renegotiates (SSL_accept())
5 server accepts that finished
4 session cache hits
0 session cache misses
0 session cache timeouts
0 callback cache hits
0 cache full overflows (128 allowed)
---
no client certificate available

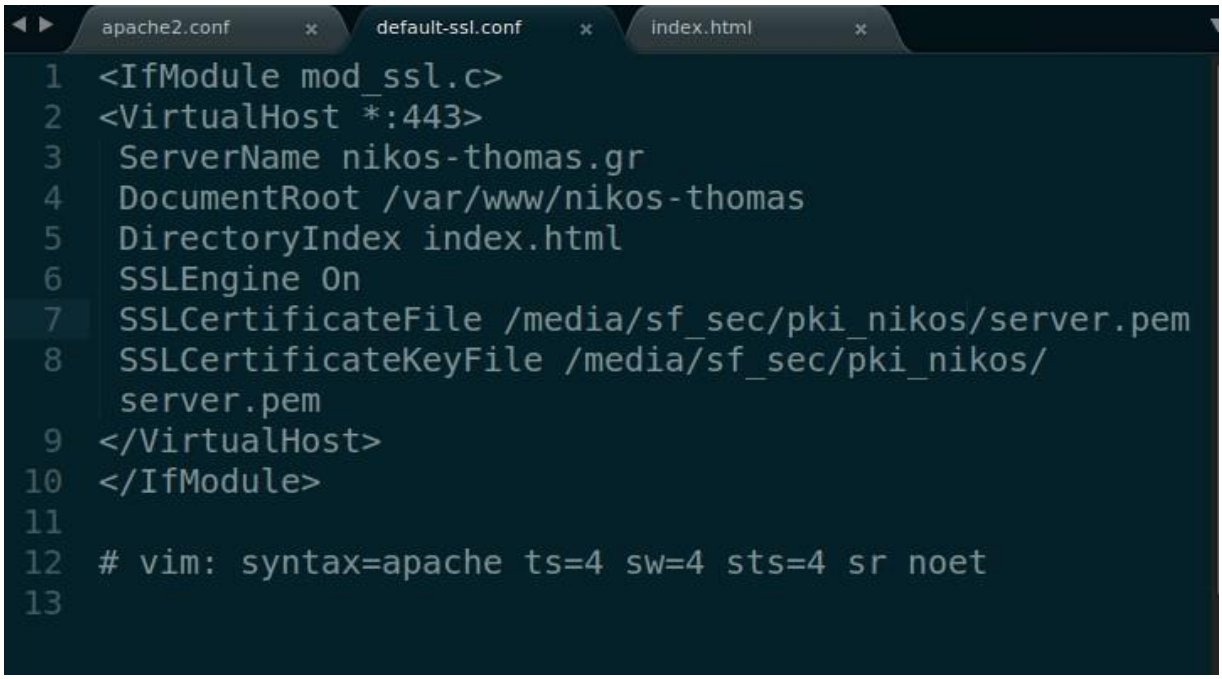

nikos-thomas.gr:4433/
https://nikos-thomas.gr:4433
Most Visited
SEED Labs
Sites for Labs
Shared Signature Algorithms: ECDSA+SHA256:ECDSA+SHA384:ECDSA+SHA512:RSA+SHA256:RSA+SHA384:RSA+SHA512:E
Supported Elliptic Curves: 0x001D:P-256:P-384:P-521:0x0100:0x0101
Shared Elliptic curves: P-256:P-384:P-521

New, TLSv1/SSLv3, Cipher is ECDHE-RSA-AES128-GCM-SHA256
SSL-Session:
Protocol : TLSv1.2
Cipher : ECDHE-RSA-AES128-GCM-SHA256
Session-ID:
Session-ID-ctx: 01000000
Master-Key: F1D2E53D75858091C74FC5F76B3F2A84F3985A530F22DC1094C327F1CE98CAF19B6ED7DD3CADEBCF568F74
Key-Arg : None
PSK identity: None
PSK identity hint: None
SRP username: None
Start Time: 1716987488
Timeout : 300 (sec)
Verify return code: 0 (ok)
---
0 items in the session cache
0 client connects (SSL_connect())
0 client renegotiates (SSL_connect())
0 client connects that finished
2 server accepts (SSL_accept())
0 server renegotiates (SSL_accept())
2 server accepts that finished
0 session cache hits
2 session cache misses
0 session cache timeouts
0 callback cache hits
0 cache full overflows (128 allowed)

Δραστηριότητα 4: Χρήση του πιστοποιητικού σε Apache HTTPS Web server



Εικόνα 21: index.html.



Εικόνα 22: Τροποποίηση του default-ssl.conf.

Τροποποίηση του αρχείου default-ssl.conf για την σωστή λειτουργία.

```
[05/31/24]seed@VM:.../sites-available$ sudo apachectl configtest
AH00558: apache2: Could not reliably determine the server's fully
 qualified domain name, using 127.0.1.1. Set the 'ServerName' dir
ective globally to suppress this message
Syntax OK
[05/31/24]seed@VM:.../sites-available$ sudo a2enmod ssl
Considering dependency setenvif for ssl:
Module setenvif already enabled
Considering dependency mime for ssl:
Module mime already enabled
Considering dependency socache_shmcb for ssl:
Module socache_shmcb already enabled
Module ssl already enabled
[05/31/24]seed@VM:.../sites-available$ sudo a2ensite default-ssl
Site default-ssl already enabled
[05/31/24]seed@VM:.../sites-available$  sudo service apache2 rest
art
Enter passphrase for SSL/TLS keys for nikos-thomas.gr:443 (RSA):
*****
[05/31/24]seed@VM:.../sites-available$
```

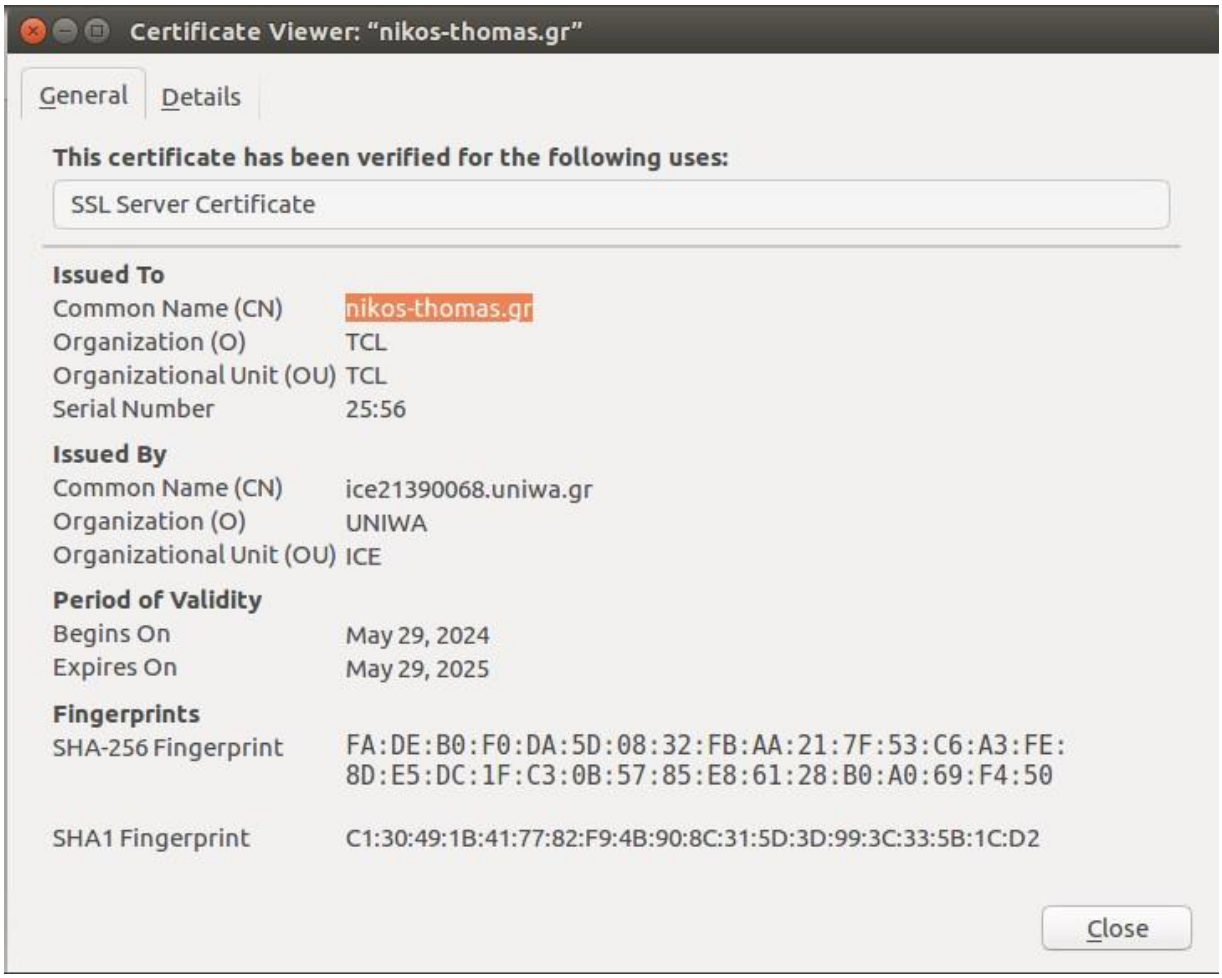
Εικόνα 23: Ενεργοποίηση του πρωτόκολλου SSL.

Μετά την εκτέλεση των εντολών αυτών και την ενεργοποίηση του πρωτοκόλλου SSL, θα μπορούμε να προηγηθούμε στο ασφαλές website.



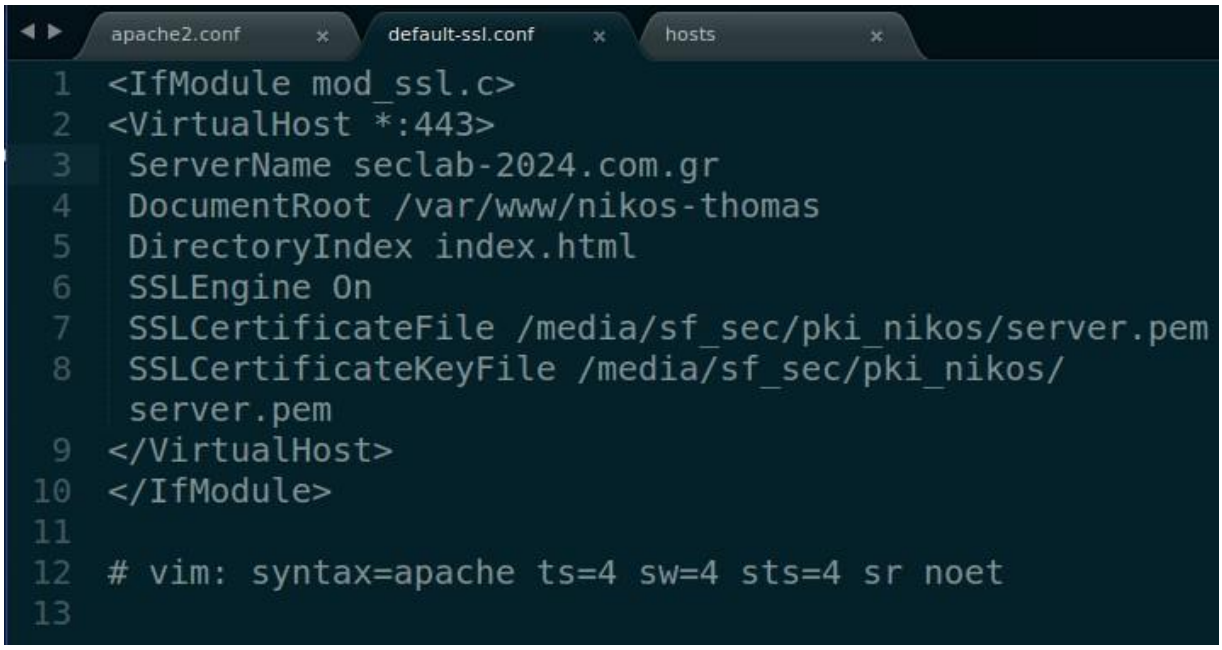
Nikos Thomas

Εικόνα 24: Ασφαλές website.

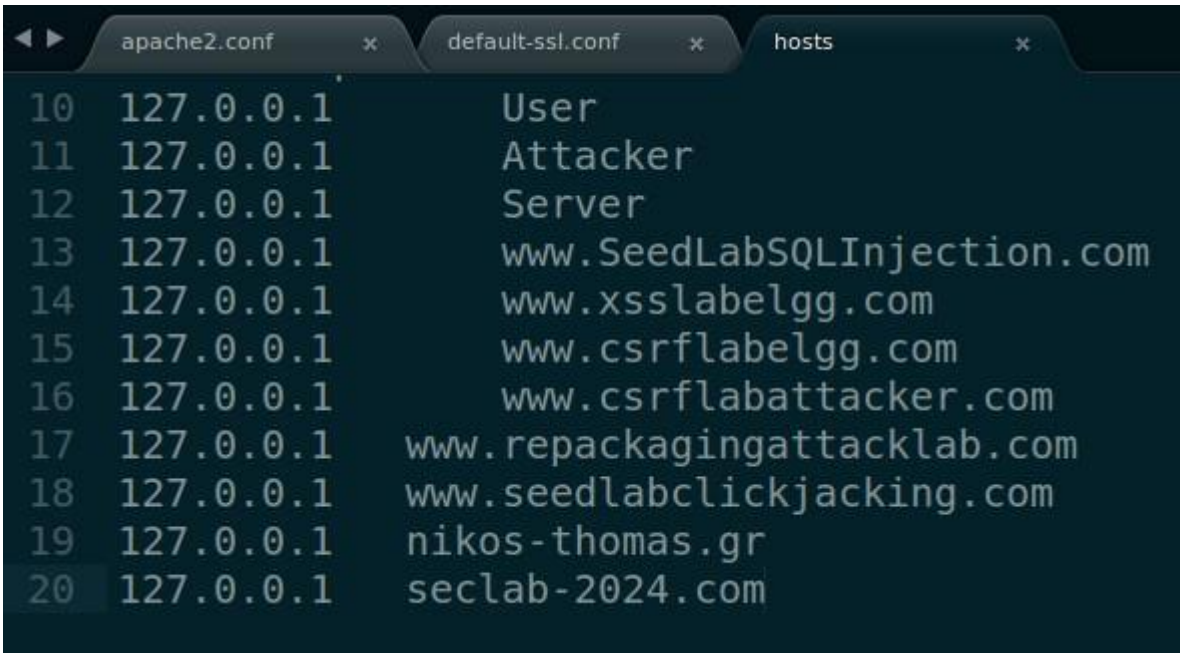


Εικόνα 25: Έλεγχος ποιστοποιητικού του website.

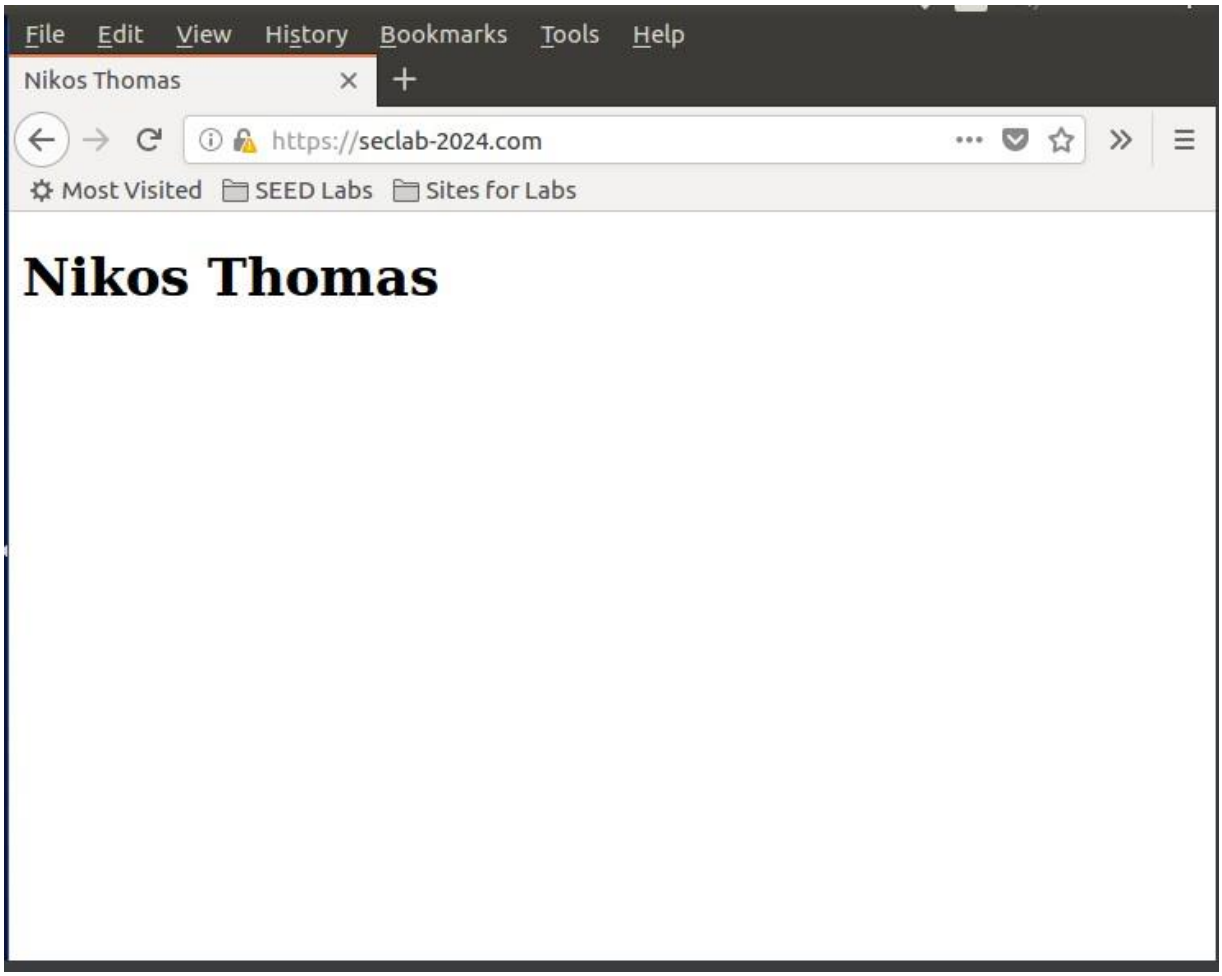
Δραστηριότητα 5: Επίθεση τύπου Man-In-The-Middle



Εικόνα 26: Τροποποίηση του default-ssl.conf.



Εικόνα 27: Τροποποίηση του /etc/hosts (DNS).



Εικόνα 28: MITM website.

Δραστηριότητα 6: Επίθεση τύπου Man-In-The-Middle σε περίπτωση παραβιασμένης ΑΠ

```
[06/07/24]seed@VM:.../mitm$ openssl genrsa -aes128 -out niko
s-mitm.key 1024
Generating RSA private key, 1024 bit long modulus
............++++++
.....................................++++++
e is 65537 (0x10001)
Enter pass phrase for nikos-mitm.key:
Verifying - Enter pass phrase for nikos-mitm.key:
[06/07/24]seed@VM:.../mitm$
```

Εικόνα 29: Δημιουργία ζεύγους κλειδιών RSA για τον πελάτη.

Στη συνέχεια δημιουργούμε το ζεύγος κλειδιών RSA για τον πελάτη με την εντολή $ openssl genrsa -aes128 -out nikos-mitm.key 1024. Τροποποιούμε κατάλληλα το openssl.cnf και default-ssl.conf.

```
[06/07/24]seed@VM:.../mitm$ openssl req -new -key nikos-mitm.key
-out nikos-mitm.csr -config openssl.cnf
Enter pass phrase for nikos-mitm.key:
You are about to be asked to enter information that will be incor
porated
into your certificate request.
What you are about to enter is what is called a Distinguished Nam
e or a DN.
There are quite a few fields but you can leave some blank
For some fields there will be a default value,
If you enter '.', the field will be left blank.
-----
Country Name (2 letter code) [AU]:MI
State or Province Name (full name) [Some-State]:MITM
Locality Name (eg, city) []:MITM
Organization Name (eg, company) [Internet Widgits Pty Ltd]:MITM
Organizational Unit Name (eg, section) []:MITM
Common Name (e.g. server FQDN or YOUR name) []:nikos-mitm.com
Email Address []:nikos@mitm.com

Please enter the following 'extra' attributes
to be sent with your certificate request
A challenge password []:nikos
An optional company name []:nikos
[06/07/24]seed@VM:.../mitm$
```

Εικόνα 30: Δημιουργία του CSR.

Δημιουργία του αιτήματος υπογραφής πιστοποιητικού (CSR) με την εντολή $ openssl req -new -key nikos-mitm.key -out nikos-mitm.csr -config openssl.cnf. Θα περιλαμβάνει το δημόσιο κλειδί του καθώς και πληροφορίες για την ταυτότητα του αιτούντος.

```
[06/07/24]seed@VM:.../mitm$ openssl req -new -x509 -keyout nikos-
mitm.key -out nikos-mitm.crt -days 365 -config openssl.cnf
Generating a 2048 bit RSA private key
.....................................................................
.........................+++
.....................................................................
.....................................................................
.....................................+++
writing new private key to 'nikos-mitm.key'
Enter PEM pass phrase:
Verifying - Enter PEM pass phrase:
Verify failure
Enter PEM pass phrase:
Verifying - Enter PEM pass phrase:
-----
You are about to be asked to enter information that will be incor
porated
into your certificate request.
What you are about to enter is what is called a Distinguished Nam
e or a DN.
There are quite a few fields but you can leave some blank
For some fields there will be a default value,
If you enter '.', the field will be left blank.
-----
Country Name (2 letter code) [AU]:mi
State or Province Name (full name) [Some-State]:mitm
```

Εικόνα 31: Αυτό-υπογεγραμμένου πιστοποιητικού της ΑΠ.

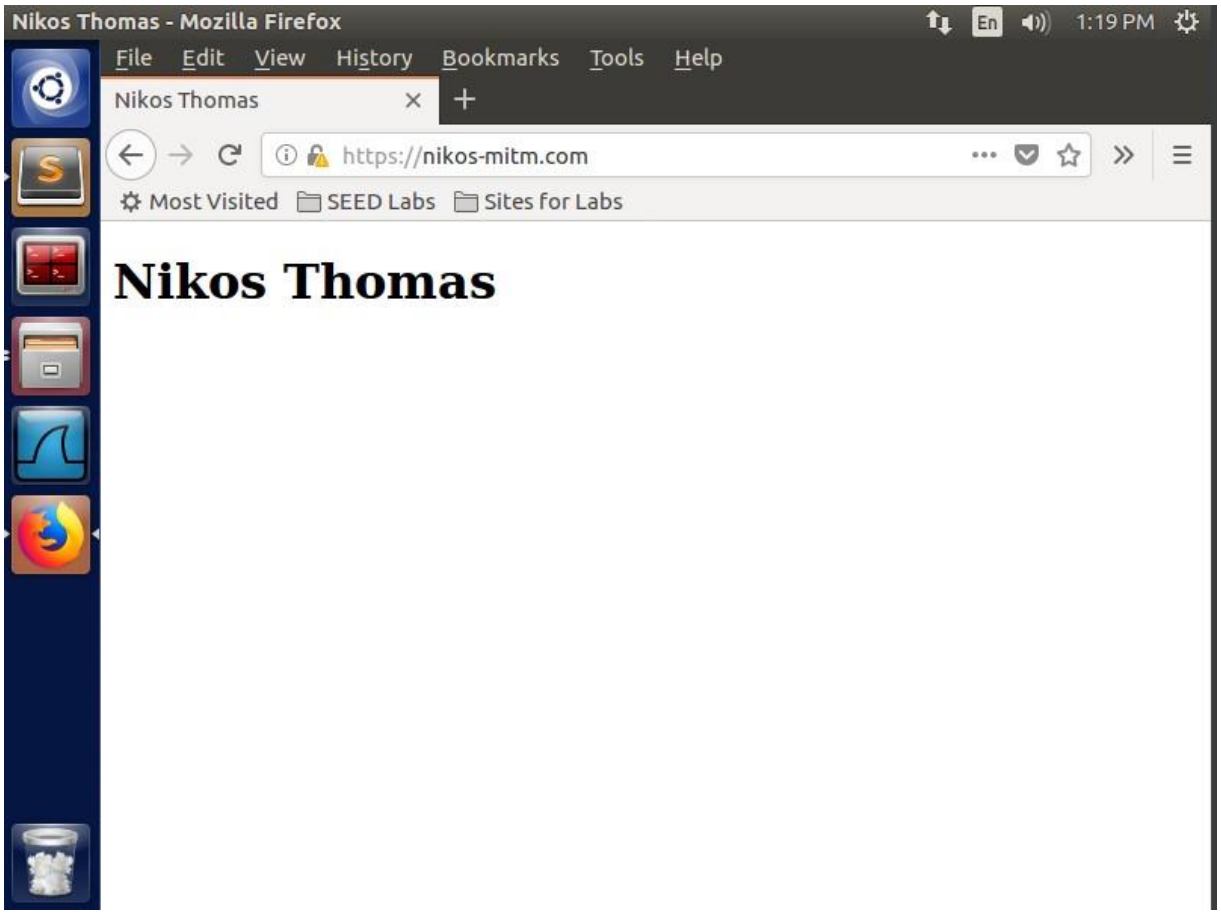
apache2.conf | hosts | default-ssl.conf | openssl.cnf | serial

```
1   127.0.0.1   localhost
2   127.0.1.1   VM
3
4   # The following lines are desirable for IPv6 capable hosts
5   ::1     ip6-localhost ip6-loopback
6   fe00::0 ip6-localnet
7   ff00::0 ip6-mcastprefix
8   ff02::1 ip6-allnodes
9   ff02::2 ip6-allrouters
10  127.0.0.1       User
11  127.0.0.1       Attacker
12  127.0.0.1       Server
13  127.0.0.1       www.SeedLabSQLInjection.com
14  127.0.0.1       www.xsslabelgg.com
15  127.0.0.1       www.csrflabelgg.com
16  127.0.0.1       www.csrflabattacker.com
17  127.0.0.1   www.repackagingattacklab.com
18  127.0.0.1   www.seedlabclickjacking.com
19  127.0.0.1   nikos-thomas.gr
20  127.0.0.1   seclab-2024.com
21  127.0.0.1   MITM
22  127.0.0.1   nikos-mitm.com
```

Εικόνα 32: Τροποποίηση του /etc/hosts (DNS).

```
[06/07/24]seed@VM:.../mitm$ cp nikos-mitm.key server.pem
[06/07/24]seed@VM:.../mitm$ cat nikos-mitm.crt >> server.pem
[06/07/24]seed@VM:.../mitm$ openssl s_server -cert server.pe
m -www
Enter pass phrase for server.pem:
Using default temp DH parameters
ACCEPT
```

Εικόνα 33: Εκκίνηση του OpenSSL web server.



Εικόνα 34: MITM website.

Παραπομπές:

Δρ. Γεωργούλας.